



FACULTY OF COMPUTING
BCN 2023
DATA & NETWORK SECURITY

PROJECT REPORT

**TITLE: VULNERABILITIES OF LIBRARY WEBSITE IN UMPSA
PEKAN**

**LECTURER: TS. DR NOORHUZAIMI@KARIMAH BINTI MOHD
NOOR**

NAME	MATRIC ID
AUNI NAJIHAH BINTI JAMARLUDDIN	CA22081
NUR A'IN NAJWA BINTI NASRA	CA22025
KHAIRINA BINTI ABDUL RAHMAN	CA22031
AYUNNI NABILAH BINTI MOHD ZUBIR	CA22052

TABLE OF CONTENT

INTRODUCTION.....	2
2. SIGNED AGREEMENTS.....	3
2.1 GROUP CONTRACT	3
2.2 PROFESSIONAL PRACTICE AND ETHICAL RESPONSIBILITIES	5
2.3 LIST OF IP AND MAC ADDRESSES	7
3. Tools Identification & Network Topology	8
3.1 Tools Used.....	8
3.2 Assets Discovery	8
3.2 Network Topology.....	19
4. Vulnerability Identification & Exploitation.....	20
4.1 UMPSA Library Website Vulnerability	20
4.2 UMPSA Library Network Vulnerability	23
5. Vulnerability Metrics (CVSS)	26
6. Exploitation.....	27
7. Remediation Plan	28
8. References	31
9. Task Distribution & Meeting Logs.....	32
9.1 Roles & Tasks.....	32
9.2 Weekly Log Summary	33
9.3 Individual Progress Sheet	35
10. Appendix	41

INTRODUCTION

Any current academic institution must guarantee the availability, confidentiality, and integrity of campus wireless networks and web-based services. The objective of this evaluation is to pinpoint and record significant weaknesses in the UMPSA Library's digital infrastructure, particularly its public-facing website and the surrounding wireless environment, and to show how these weaknesses could be used in a completely moral or in other way we called white hat. By integrating web-application testing and on-site wireless surveillance, the objective is to find configuration errors or oversights before attackers can exploit them and then provide explicit, prioritised remedy advice.

This work's scope covers two main topics. Initially, both automated and manual scans will be performed on the UMPSA Library website, including directory indexing checks, HTTP header analysis and cookie flag validation to find any setup errors that could enable an attacker to obtain private data or move forward within the system. Second, we will map all visible SSIDs within the Library, record channel usage and signal strength, and connect to any open or insecure networks using a Kali Linux laptop and the mobile Wi-Fi analyser software VREM. After connecting, hosts, services, and open ports will be listed using programs like Nmap, which show how an unauthorised user could access the UMPSA's library network.

White-hat hacking is an essential teaching tool because it allows us to proactively enhance defences without causing harm by mimicking real-world attack strategies with express faculty agreement. The UMPSA Library was chosen as a high-impact target because it supports a diverse population of users, including lecturers, staff and students who depend on it. Furthermore, with public-facing web servers and mixed-use Wi-Fi, university library networks usually offer a typical academic setting. By concentrating on this clearly defined attack surface, the evaluation offers real-world, experiential learning while upholding strict ethical guidelines and obtaining consent from all parties involved.

2. SIGNED AGREEMENTS

2.1 GROUP CONTRACT

Project Title: Vulnerabilities of Library Website in UMPSA

Date: 27/3/2025

Contract Items

1. Participation

- Each member must contribute equally to discussions, research, and execution of tasks.
- Active participation in all meetings and assignments is required.
- Failure to participate without valid reasons may lead to reassignment of responsibilities.

2. Communication

- The primary mode of communication will be via WhatsApp.
- Urgent matters must be communicated immediately to the group leader.
- All members must respond within 24 hours to messages related to project updates.

3. Meetings

- Weekly meetings will be held on scheduled by group leaders.
- Attendance is compulsory unless prior notice is given.
- Meeting minutes will be recorded and shared with all members.

4. Conduct

- Members must maintain professionalism and respect towards each other.
- All work must be original, and ethical hacking guidelines must be followed.
- Any form of misconduct will be reported to the lecturer.

5. Deadlines

- All tasks must be completed at least **24 hours before the actual deadline** for review.
- Late submissions without valid reasons will affect the member's contribution score.

6. Conflict Resolution

- Disputes will be resolved through group discussion first.
- If unresolved, the issue will be escalated to the lecturer.

7. Clause for Violation

- Any member failing to meet responsibilities will receive **one warning**.
- Continuous failure may lead to role reassignment or reporting to the lecturer.

Group Member Roles and Contributions:

Student ID	Name	Role & Contribution	Signature
CA22025	NUR A'IN NAJWA BINTI NASRA	Role: White hat hackers Contribution: Conduct a comprehensive vulnerabilities scan of library website	
CA22031	KHAIRINA BINTI ABDUL RAHMAN	Role: White hat hackers Contribution: Conduct network scanning and asset discovery	
CA22081	AUNI NAJIHAH BINTI JAMARLUDDIN	Role: White hat hackers Contribution: Find remediation strategies of vulnerabilities	
CA22052	AYUNNI NABILAH BINTI MOHD ZUBIR	Role: White hat hackers Contribution: Find tools to find the vulnerabilities of the library website	

Assessor: Ts. Dr Noorhuzaimi@Karimah Binti Mohd Noor

Date Received: 28/3/2025

2.2 PROFESSIONAL PRACTICE AND ETHICAL RESPONSIBILITIES

Project Title: Vulnerabilities of Library Website in UMPSA

Date of Agreement: 27/3/2025

1. Scope of Work

- The team is authorized to conduct ethical vulnerability testing on selected campus networks which is UMPSA library website.
- Testing includes network scanning, security assessment, and remediation strategy formulation.
- This project will use Kali Linux as the penetration testing platform and Nikto for web vulnerability scanning. As the assessment continues, more tools might be added.

2. **Permission & Authorization**

- Activities will comply with university security policies.
- No unauthorized access beyond project scope is allowed.

3. **Legal and Ethical Responsibilities**

- Members must adhere to ethical hacking principles.
- Data confidentiality must be always maintained.
- Any discovered vulnerability must be reported responsibly.

4. **Code of Ethics**

- No personal or sensitive information will be disclosed.
- The project must be conducted legally and transparently.

5. **Confidentiality**

- All test findings and data are confidential and must not be shared outside the project team or lecturer.

6. **Reporting and Documentation**

- Regular updates will be provided to the lecturer.
- A final report with findings and remediation plans will be submitted.

7. **Termination**

- This agreement is valid until the project completion unless terminated by the lecturer.

Signatures:

Name	Signature	Date
------	-----------	------

NUR A'IN NAJWA BINTI NASRA		27/3/2025
KHAIRINA BINTI ABDUL RAHMAN		27/3/2025
AUNI NAJIHAH BINTI JAMARLUDDIN		27/3/2025
AYUNNI NABILAH BINTI MOHD ZUBIR		27/3/2025

Approval by Lecturer:

Lecturer Name: Ts. Dr Noorhuzaimi@Karimah binti Mohd Noor

Signature: _____

Date: _____

2.3 LIST OF IP AND MAC ADDRESSES

Device	IP Address	MAC Address	Connection Type
--------	------------	-------------	-----------------

KMC1000-MEDIA2 Desktop	10.19.23.33	EC:B1:D7:5B:CC:98	Ethernet
TVOE7OL-Desktop	10.19.23.83	D4:93:90:0C:CD:4D	Ethernet
ASIX Computer	10.19.23.80	F8:E4:3B:90:5D:D4	Ethernet
C93-24-LIB-GR1 Router	10.19.23.254	C4:7E:E0:74:4B:C4	Ethernet

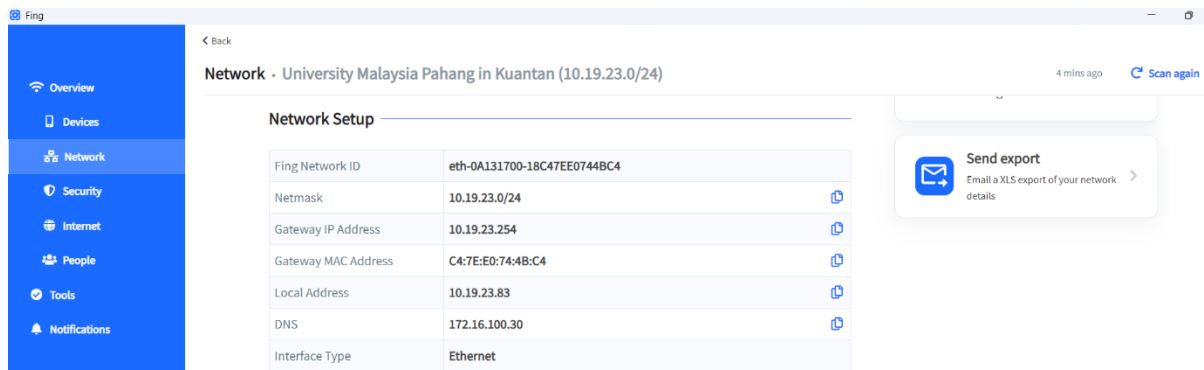
3. Tools Identification & Network Topology

3.1 Tools Used

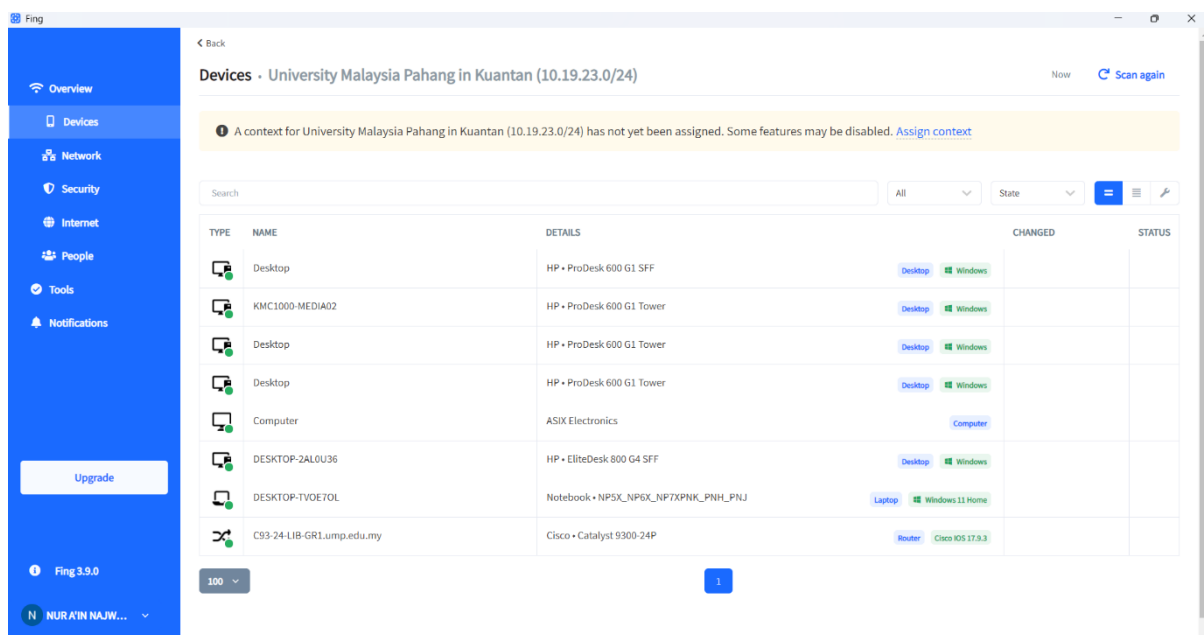
Tool	Purpose	Configuration/Usage
Fing	Device discovery, scanning, and footprinting.	Scan the local network for all active IPs, MAC addresses, and device names in LAN using laptop.
WiFiAnalyzer	Displays the MAC address of each Access Point by wireless scanning and signal analysis.	Shows nearby WiFi networks, AP MAC addresses, and signal strength which helps locate strong and weak WiFi zones.
Kali Linux	Penetration Testing Toolkit and enumeration.	We use Nmap for identifying Netdiscover.
Nikto	To discover the vulnerabilities in UMPSA Library website	Nikto -h https://library.umpsa.edu.my
Camera	Physical observation	Capture pictures of exposed access points and open ports on devices or wall-mounted in the library.

3.2 Assets Discovery

By using fing, we can discover library's ethernet port private IP is 10.19.23.0/24 which means there are 256 IP addresses available, which are from 10.19.23.1 to 10.19.23.254.



After successfully connect to the network, fing could automatically access information like devices that is in the network.



However, there are only 8 active devices discovered.

Device Name	Type	Model	OS	Manufacturer	Purpose
-------------	------	-------	----	--------------	---------

(Unnamed desktop)	Desktop	HP ProDesk 600 G1 SFF	Windows	HP	Lab or office workstation
KMC1000 – MEDIA02	Desktop	HP ProDesk 600 G1 Tower	Windows	HP	Likely media or resources PC
(Unnamed desktop)	Desktop	HP Prodesk 600 G1 Tower	Windows	HP	Standard desktop PC
(Unnamed desktop)	Desktop	HP Prodesk 600 G1 Tower	Windows	HP	General-purpose system
(Unnamed Computer)	Computer	Unknown	Unknown	ASIX Electronics	Possibly a network peripheral
DESKTOP-2ALOU36	Desktop	HP EliteDesk 800 G4 SFF	Windows	HP	High-end desktop
DESKTOP – TVOE70L	Laptop	NP5X_NP6X_NP7XPNK_PNH_PNJ	Windows 11 Home	Notebook	Student laptop (our laptop)
C93-24-LIB-GR1.ump.edu.my	Router	Cisco Catalyst 9300-24P	Cisco IOS 17.9.3	Cisco	Core network router

We could monitor device's information when clicking on any device that we want.

Example of what information we could collect on router;

The screenshot displays the Fing application interface for a specific device, 'C93-24-LIB-GR1.ump.edu.my'. The interface is divided into several sections:

- Header:** Shows the device name, status (Online, 6 minutes ago), and options to 'Change', 'Important', or 'Edit device details'.
- Navigation Sidebar:** Includes links for Overview, Devices, Network, Security, Internet, People, Tools, and Notifications.
- Network Setup:** A table listing key information:

IP Address	10.19.23.254
MAC Address	C4:7E:E0:74:4B:C4
Serial No	N/A
First seen	3:54 PM
Last change	N/A
- Device Details:** A table showing the brand and model:

Brand	Cisco
Family	Catalyst
Model	Catalyst 9300-24P
- Improve security:** A section with three actionable cards: 'Find Open Ports', 'Limit internet time', and 'Block network access', each with a status indicator and a right arrow for more options.
- Notifications:** A section titled 'Notify me when state changes' with a toggle switch and a description: 'Receive a notification when this device goes online or offline.' Below this is a prompt to 'Define how long a device must be absent to be'.

Fing

Overview

Devices

Network

Security

Internet

People

Tools

Notifications

Upgrade

Fing 3.9.0

NUR'AIN NAJW...

Back to list of devices

Device details

Change

C93-24-LIB-GR1.ump.edu.my

Cisco Catalyst 9300-24P • Cisco IOS 17.9.3

Important

Edit device details

Online

6 minutes ago

Clear from device list

View timeline

Network setup

Device

Operating System

Protocols

Solutions

Device life cycle

Release date	Jun 2017
Warranty	check

Product value

Price class	N/A
Product class	Consumer Enterprise
Popularity	

Operating System

Brand and version

Brand	Cisco
Name	Cisco IOS
Version	Cisco IOS 17.9.3

Automatic ("10" min)

Confirm your device

This device isn't recognized as yours in this network

Owner not found

Not tracking

Troubleshooting tools

Ping

Visualize the response time of a device or website

Traceroute

Measure the transit delays across

Fing

Overview

Devices

Network

Security

Internet

People

Tools

Notifications

Upgrade

Fing 3.9.0

NUR'AIN NAJW...

Back to list of devices

Device details

Change

C93-24-LIB-GR1.ump.edu.my

Cisco Catalyst 9300-24P • Cisco IOS 17.9.3

Important

Edit device details

Online

6 minutes ago

Clear from device list

View timeline

Network setup

Device

Operating System

Protocols

Solutions

Operating System

Brand and version

Brand	Cisco
Name	Cisco IOS
Version	Cisco IOS 17.9.3

Did Fing get it right?

Your feedback helps us improve device recognition results

Yes

No

Operating system life cycle

Release date	Mar 2023
--------------	----------

Protocols

SNMP

Name	C93-24-LIB-GR1.ump.edu.my
------	---------------------------

Troubleshooting tools

Ping

Visualize the response time of a device or website

Traceroute

Measure the transit delays across the network

Wake on LAN

Wake up devices that have been set up to receive Wake-On-Lan packets

Fing

Overview

Devices

Network

Security

Internet

People

Tools

Notifications

Upgrade

Fing 3.9.0

NUR'AIN NAJW...

Back to list of devices

Device details

Change

C93-24-LIB-GR1.ump.edu.my

Cisco Catalyst 9300-24P • Cisco IOS 17.9.3

Important

Edit device details

Online

6 minutes ago

Clear from device list

View timeline

Network setup

Device

Operating System

Protocols

Solutions

Operating system life cycle

Release date

Mar 2023

Protocols

SNMP

Name	C93-24-LIB-GR1.ump.edu.my
Description	Cisco IOS Software [Cupertino], Catalyst L3 Switch Software (CAT9K_IOSXE), Version 17.9.3, RELEASE SOFTWARE (fc6) Technical Support: http://www.cisco.com/techsupport Copyright (c) 1986-2023 by Cisco Systems, Inc. Compiled Tue 14-Mar-23 18:26 by mcpre
Services	Internet Datalink/Subnetwork

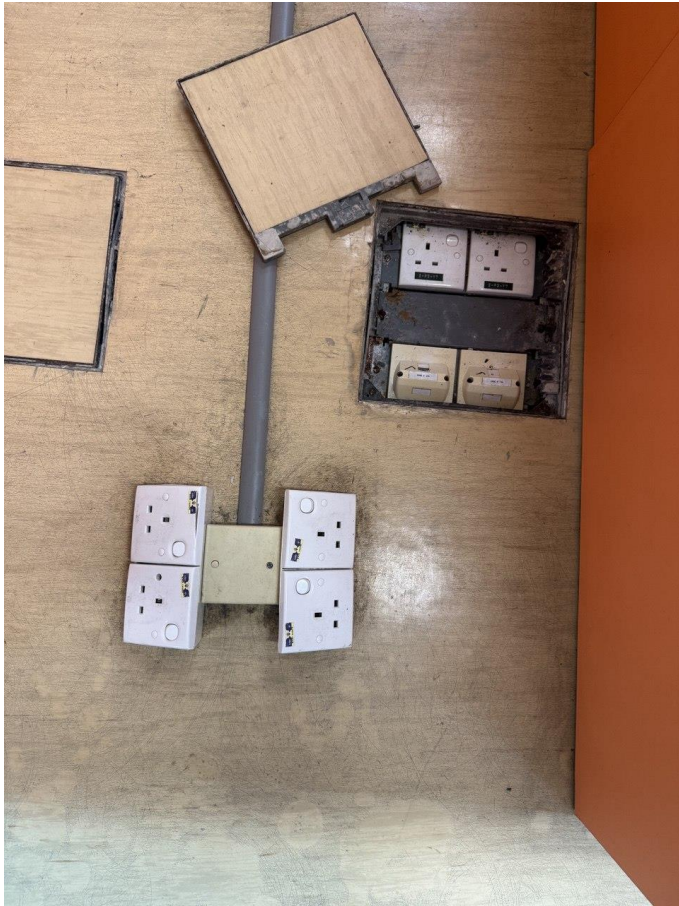
Solutions

Cisco Catalyst 9300-24P

Cisco Cisco IOS

Wake up devices that have been set up to receive Wake-On-Lan packets

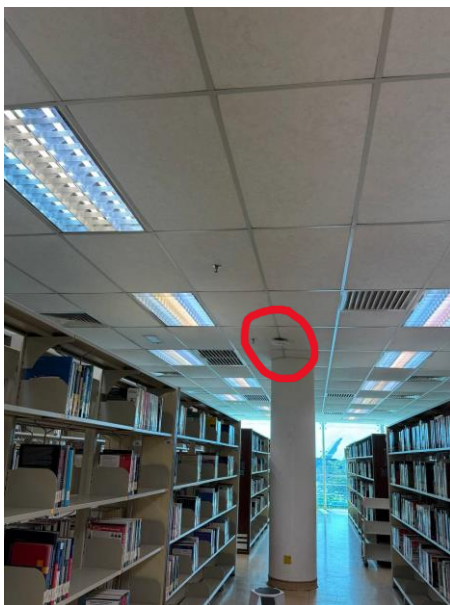
All of this information could be gathered because there is an open access point that allow anyone to enter the network.







There are also many exposed wireless access point (WAP) in library;



Among bookshelves area.



In the computer lab area.



At the hallway.



At the library's main door.



At study area.

3.2 Network Topology

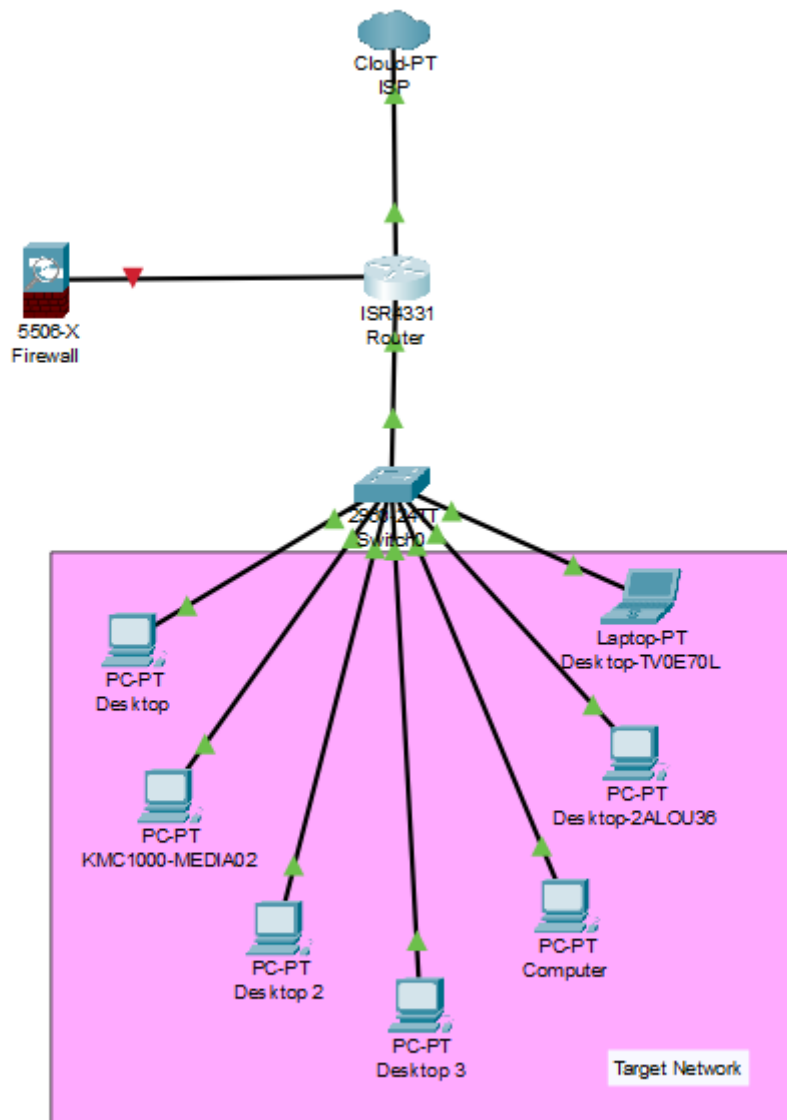


Figure 3.2, network topology of UMPSA Library Test Area

4. Vulnerability Identification & Exploitation

4.1 UMPSA Library Website Vulnerability

1. Vulnerability: Missing Strict-Transport-Security Header

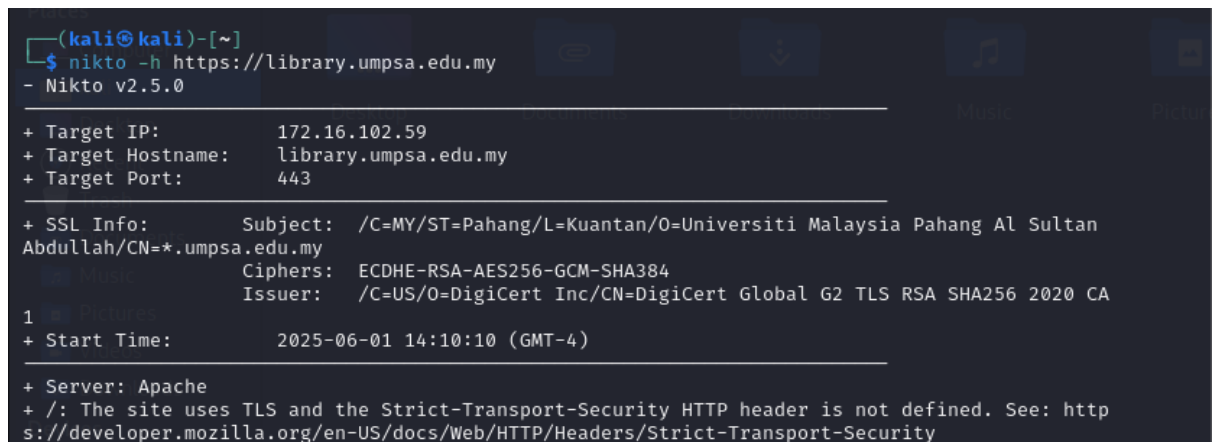
Tool Used: Nikto

Target: <https://library.umpsa.edu.my> (172.16.102.59)

Steps:

1. Ran nikto -h <https://library.umpsa.edu.my>
2. Nikto discovered missing Strict-Transport-Security (HSTS) header
3. Verified at MDN documentation (<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security>)

Screenshot:



```
(kali㉿kali)-[~]
$ nikto -h https://library.umpsa.edu.my
- Nikto v2.5.0

+ Target IP: 172.16.102.59
+ Target Hostname: library.umpsa.edu.my
+ Target Port: 443

+ SSL Info: Subject: /C=MY/ST=Pahang/L=Kuantan/O=Universiti Malaysia Pahang Al Sultan
Abdullah/CN=*.umps.edu.my
Ciphers: ECDHE-RSA-AES256-GCM-SHA384
Issuer: /C=US/O=DigiCert Inc/CN=DigiCert Global G2 TLS RSA SHA256 2020 CA
1
+ Start Time: 2025-06-01 14:10:10 (GMT-4)

+ Server: Apache
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: http
s://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
```

Result: Vulnerability confirmed

2. Vulnerability: Missing X-Content-Type-Options Header

Tool Used: Nikto

Target: <https://library.umpsa.edu.my> (172.16.102.59)

Steps:

1. Ran nikto -h <https://library.umpsa.edu.my>
2. Nikto discovered missing X-Content-Type-Options
3. Verified at Netsparker Invicti (<https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/>)

Screenshot:

```
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

Result: Vulnerability confirmed

3. Vulnerability: Website has a Cookie Without Secure Flag

Tool Used: Nikto

Target: <https://library.umpsa.edu.my> (172.16.102.59)

Steps:

1. Ran nikto -h <https://library.umpsa.edu.my>
2. Nikto discovered that cookie **70155ae48558265d1a753cb050a8201c** has create without the secure flag.
3. Verified at MDN Documentation (<https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/Cookies>)

Screenshot:

```
+ /: Cookie 70155ae48558265d1a753cb050a8201c created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
```

Result: Vulnerability confirmed

4. Vulnerability: Website has robots.txt Reveals Sensitive Paths

Tool Used: Nikto

Target: <https://library.umpsa.edu.my> (172.16.102.59)

Steps:

1. Ran nikto -h <https://library.umpsa.edu.my>
2. Nikto detected many sensitive directories listed in robots.txt, such as /log/, /language/, /tmp/, /cache/ and /bin/
3. Verified at PortSwigger Documentation (https://portswigger.net/kb/issues/00600600_robots-txt-file)

Screenshot:

```
+ Root page / redirects to: https://library.umpsa.edu.my/index.php/en/
+ /robots.txt: Entry '/logs/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/cache/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/language/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/tmp/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/bin/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
```

Result: Vulnerability confirmed

5. Vulnerability: Directory Indexing Found

Tool Used: Nikto

Target: <https://library.umpsa.edu.my> (172.16.102.59)

Steps:

1. Ran nikto -h <https://library.umpsa.edu.my>
2. Nikto detected that /icons/ has allow the directory listing
3. Verified at VNTWeb Documentation (<https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/>)

Screenshot:

```
+ /icons/: Directory indexing found.
+ /LICENSE.txt: License file found may identify site software.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /htaccess.txt: Default Joomla! htaccess.txt file found. This should be removed or renamed.
```

Result: Vulnerability confirmed

4.2 UMPSA Library Network Vulnerability

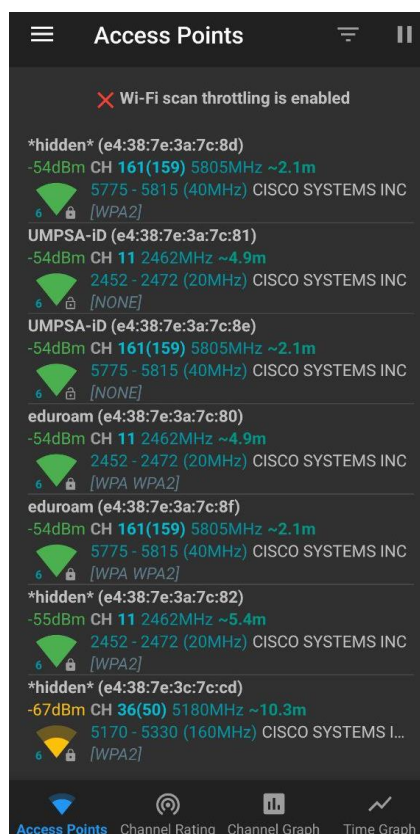
1. Vulnerability : Discover Nearby SSIDs and Access Points

Tool Used: WiFiAnalyzer

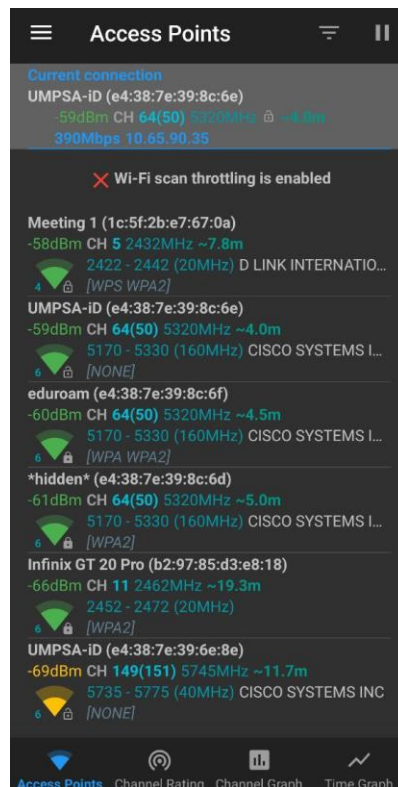
Zone Area: Inside Library

Steps:

1. Download the WiFiAnalyzer in the Android phone.
2. Go to the zone area and bring the phone so it can scan the Wi-Fi in that zone.
3. In this app, you can easily see which SSIDs are associated with library network for example UMPSA-iD and other devices networks
4. The app provides a real-time signal level in dBm for every Access Point. By moving around with the app open, you can see the strength of a certain AP's signal in each zone
5. If an AP is open (not encrypted), WPA2, WPA/WPA2, WPA3, or even WPS, it shows that information.



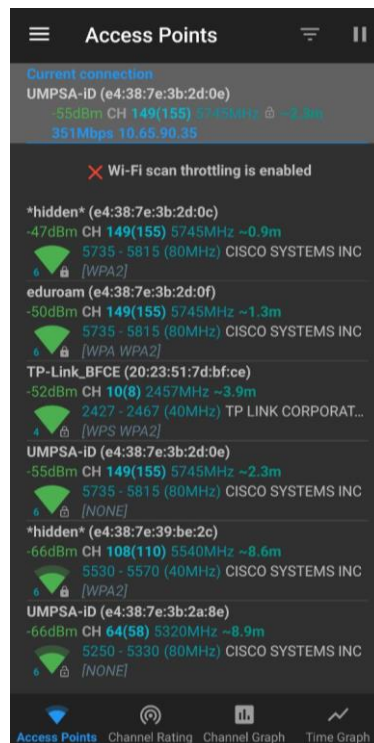
Zone Area: Library Entrance



Zone Area: Discussion Room



Zone Area: Computer Lab



Zone Area: Book Rack



Zone Area: Community Area

As you can see in UMPSA-iD is transmitting without encryption ("[NONE]" shown). Anyone in the facility can connect to the network without a password if the SSID is open. An attacker who connects can sniff traffic to obtain network data or even intercept application data that isn't secured. On CH 149 in the Book Rack Zone, a hidden SSID (no apparent name) that was exclusively WPA2-secured surfaced. In reality, concealing an SSID does not increase security because clients need to send out "probe requests" searching for that network, which an attacker can intercept to determine which devices are connected. Furthermore, an attacker can attempt offline brute-forcing of WPA2 credentials by simply causing a reauthentication and capturing the 4-way handshake once they know the BSSID.

5. Vulnerability Metrics (CVSS)

Use NIST CVSS calculator: <https://nvd.nist.gov/vuln-metrics/cvss> (version 3.1)

Vulnerability	CVE ID	CVSS Score	Severity	Link	Vulnerability
Missing Strict-Transport-Security Header	-	4.3	Medium	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security	The lack of HSTS enables SSL stripping attacks. HTTPS should be enforced.
Missing X-Content-Type-Options Header	-	4.3	Medium	https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header	MIME-sniffing attacks might be possible.
Website has a Cookie Without Secure Flag	-	5.4	Medium	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/Cookies	Allows HTTP communication, which exposes cookies to interception.

Website has robots.txt Reveals Sensitive Paths	-	5.3	Medium	https://portswigger.net/kb/issues/00600600_robots-txt-file	Attackers can conduct recon using exposed directories such as /logs/ and /bin/.
Directory Indexing Found	-	5.0	Medium	https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/	A directory listing may reveal files that are not intended for the public.

6. Exploitation

1.

```
(kali@kali)-[~]
└─$ sudo nmap -sP 10.0.2.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-27 03:44 EDT
Nmap scan report for 10.0.2.2
Host is up (0.00047s latency).
MAC Address: 52:54:00:12:35:02 (QEMU virtual NIC)
Nmap scan report for 10.0.2.3
Host is up (0.00052s latency).
MAC Address: 52:54:00:12:35:03 (QEMU virtual NIC)
Nmap scan report for 10.0.2.4
Host is up (0.00065s latency).
MAC Address: 52:54:00:12:35:04 (QEMU virtual NIC)
Nmap scan report for 10.0.2.15
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.28 seconds
```

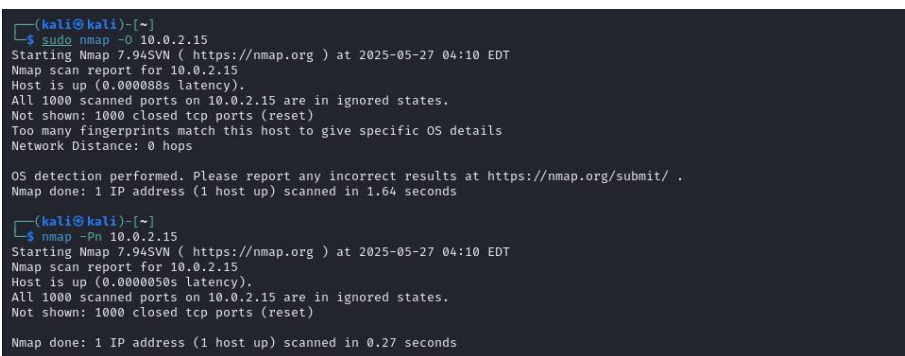
It sends ICMP echo pings as well as ARP requests on local networks. It determines which IP addresses are "up" (active) inside the range.

2.

```
(kali@kali)-[~]
└─$ nmap -sV 10.0.2.15
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-27 03:48 EDT
Nmap scan report for 10.0.2.15
Host is up (0.000050s latency).
All 1000 scanned ports on 10.0.2.15 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.58 seconds
```

This command directs version detection to be carried out. It also means that it will attempt to determine which services and what versions are operating on the open ports.

3. 

Sudo nmap -O 10.0.2.15 will carries out OS detection. By analyzing answers to specific packets, Nmap attempts to determine the target's operating system. Ping and host discovery are skipped by -Pn. It searches the host despite assuming it is up. Useful when ping is banned (for example, by a firewall), but ports remain open.

7. Remediation Plan

Vulnerability	Remediation
Missing Strict-Transport-Security Header	- Update and patch web server by applying latest OS patches to mitigate any related security flaws. sudo apt update && sudo apt upgrade apache2 nginx - Configure HSTS in web server. For Apache: <pre><IfModule mod_headers.c> Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" </IfModule></pre> Restart server to apply changes: sudo systemctl restart apache2 # or nginx - Configure access control Enforce HTTPS redirects at all endpoints: <pre>RewriteEngine On RewriteCond %{HTTPS} !=on RewriteRule ^/?(.*) https://%{SERVER_NAME}/\$1 [R=301,L]</pre>

	Disable HTTP completely if not needed. 4. Update Firewall and IDS/IPS Rules Use firewall rules to block unencrypted HTTP (port 80) traffic: sudo ufw deny http sudo ufw allow https Enable HTTPS inspection rules in IDS/IPS (e.g., Snort, Suricata):
Missing X-Content-Type-Options Header	1. Patch and Update Web Server sudo apt update && sudo apt upgrade apache2 nginx 2. Configure the X-Content-Type-Options Header <pre><IfModule mod_headers.c> Header set X-Content-Type-Options "nosniff" </IfModule></pre> Restart web server to apply the changes: <pre>sudo systemctl restart apache2</pre> 3. Configure Access Controls and Secure Content Delivery - Make sure that all resources (such as JS and CSS) have correct Content-Type headers. - Set up any available file upload methods to confirm MIME types and extensions. - Limit the kinds of files that may be uploaded or entered into forms. - Unless specifically required, prevent immediate access to uploaded files. 4. Firewall and IDS/IPS Configuration To identify executable files provided with wrong types, for example, enable rules for MIME-based assaults.
Website has a Cookie Without Secure Flag	1. Patch and update web server & app framework. <pre>sudo apt update && sudo apt upgrade apache2 nginx php</pre> 2. Enforce Secure Cookies in the Configuration of the Application Set up cookies to contain the Secure flag, depending on the backend language being used: <pre><IfModule mod_headers.c> Header edit Set-Cookie ^(.*)\$ "\$1; Secure" </IfModule></pre> PHP (if used): <pre>ini_set('session.cookie_secure', 1);</pre>

	JAVA(Servlet/Filter): <code>response.setHeader("Set-Cookie", "JSESSIONID=abc123; Secure; HttpOnly");</code> Node.js: <code>app.use(session({ secret: 'yourSecret', cookie: { secure: true }) }));</code> 3. Configure Access Controls and Password Policies - Session IDs should be routinely rotated and secured server-side. - Put secure authentication sessions into action: - Make use of brief session lives. - Make that all session cookies have the Secure and HttpOnly settings set. - Refresh session IDs when logging in and changing privileges. 4. Firewall and IDS/IPS Configuration Block port 80 (HTTP) or enforce redirection to HTTPS: <code>sudo ufw deny http</code> <code>sudo ufw allow https</code>
Website has robots.txt Reveals Sensitive Paths	1. Update and Patch Web Server and Application <code>sudo apt update && sudo apt upgrade apache2 nginx php</code> 2. Reconfigure robots.txt and Harden Access Controls 1.Minimize sensitive path exposure. 2.Restrict Access via .htaccess or Web Server Config 3.Implement Proper File Permissions 3. Firewall Rules and Access Control Lists (ACLs) Block external access to internal application directories with firewall rules Implement URL-based ACLs Intrusion Detection/Prevention System (IDS/IPS)
Directory Indexing Found	1. Patch and Update Web Server <code>sudo apt update && sudo apt upgrade apache2 nginx</code> 2. In the Web Server Configuration, turn off directory indexing.

	First, locate Apache config or .htaccess file. Then, disable Indexes for the relevant directory. <code><Directory "/var/www/html/icons"></code> Options -Indexes <code></Directory></code> Lastly, restart Apache <code>sudo systemctl restart apache2</code> 3. Configure access controls <code><Directory "/var/www/html/icons"></code> Require all denied <code></Directory></code> 4. Firewall rules and access control lists can be used to block automated tools or suspicious access to known indexed folders. IDS/IPS by enabling directory traversal and index access detection rules in Snort, Suricata or OSSEC.
--	--

8. References

1. Neil, & Neil. (2020, December 31). *Apache Restricting Access to /icons/readme* • VNTweb. VNTweb CMS Website Design and Development.
<https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/>
2. *Strict-Transport-Security header - HTTP* | MDN. (2025, May 23). MDN Web Docs.
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security>
3. *Using HTTP cookies - HTTP* | MDN. (2025, April 8). MDN Web Docs.
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/Cookies>
4. Invicti. (2025, May 26). *Missing Content-Type header detected on web application* | Invicti. <https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/>
5. *Robots.txt file*. (n.d.). PortSwigger.
https://portswigger.net/kb/issues/00600600_robots-txt-file

6. *Nikto Web vulnerability scanner* | *HackerTarget.com*. (2024, October 31).

HackerTarget.com. <https://hackertarget.com/nikto-website-scanner/>

7. OWASP Foundation. (n.d.). *OWASP top ten*. OWASP. <https://owasp.org/www-project-top-ten/>

9. Task Distribution & Meeting Logs

9.1 Roles & Tasks

Name	Role	Tasks
Auni Najihah Binti Jamarluddin	White Hate Hackers	- Find remediation strategies of vulnerabilities - analyze any type of physical vulnerabilities at UMPSA library. -Network Topology
Nur A'in Najwa Binti Nasra	White Hate Hackers	- Conduct a comprehensive vulnerabilities scan of library website using fing - Discover devices in the network and its ip addresses. -Network Topology
Khairina binti Abdul Rahman	White Hate Hackers	-Vulnerability identification - Exploitation -Vulnerability Metrics (CVSS) -Network Topology
Ayunni Nabilah binti Mohd Zubir	White Hate Hackers	- Give ideas for the tools to test the vulnerabilities and give instruction how to apply it (Wi-Fi Analyzer, Fing and Nikto). - Introduction - Vulnerability identification

		-Network Topology
--	--	-------------------

9.2 Weekly Log Summary

WEEK	ACTIVITIES	EVIDENCE
3	-Discussing suitable area -Task distribution - Set and adjust agreement between group members - Complete group contract	
6	Identifying items and steps needed to complete assets discovery, vulnerabilities identification and exploitation.	
8	Lining out steps to do each tasks and determine who will download each tools.	
10	Group work in the target's area - library. Each group members carry out each task to achieve project's goals.	

12	Final meeting; 1. Discussing results gathered and align it with rubric. 2. Rechecking final report. 3. Identify any mistake and correction needed in the report.	
----	---	---

9.3 Individual Progress Sheet

Student ID and Name: AYUNNI NABILAH BINTI MOHD ZUBIR (CA22052) Project Title: VULNERABILITIES OF LIBRARY WEBSITE IN UMPSA PEKAN		
Week	My weekly log	References used / Notes
2	Group Formation and Discussion - Discuss about group contract and title My task - Make platform in word for group contract	Notes: Discussion about group contract, the content and submission
3	Group Formation and Discussion - Discussion about title and group contract content My task - Suggest idea for tools will be used - Confirming the title project and the tools	Notes: Discuss about the library building and the content of the group contract Reference: Tools called nikto: <i>Nikto Web vulnerability scanner</i> <i>HackerTarget.com</i> . (2024, October 31). HackerTarget.com. https://hackertarget.com/nikto-website-scanner/
6	Group Formation and Discussion - Discuss about going to the targeted place - Distribute tools for each member My task - Give objective on how to execute the plan for discover vulnerability at the library	Notes: Build planning and assign tools for the simulation
8	Group Formation and Discussion - Lining out steps to do each task and determine who will download each tools	Notes: Outlining the execution plan to help members understand clearer

	My task - Download VREM and give idea to execute steps for the task	
10	Group Formation and Discussion - Group work in the target's area - library. My task - Download the VREM in order to find the vulnerability	Notes: Walking around the library at each outlining zones and record the output of the VREM (WifiAnalyzer)
12	Group Formation and Discussion - Discuss about report My task - Correct the mistakes in the report and do my part	Notes: Explain about the vulnerabilities and correct the mistakes of the task

Student ID and Name: KHAIRINA BINTI ABDUL RAHMAN (CA22031) Project title: VULNERABILITIES OF LIBRARY WEBSITE IN UMPSA PEKAN		
Week	My weekly log	Reference used / notes
2	Group Formation and Discussion -Discuss about group contract and title	Notes: -To understand project requirement.
3	Group Formation and Discussion Individual task -Research on the tools that have been suggested	References: -Fing: www.fing.com/news/best-free-network-ip-scanner/#:~:text=Fing%20helps%20you%20identify%20intruders,device%20that's%20on%20the%20network.
6	Group Formation and Discussion -Assigned roles to each member Individual task -Make a research based on the roles that have been assigned	Notes: All the group members have their own roles.
8	Group Formation and Discussion -Determine who will download the tools Individual task -My tools are nmap and nikto in kali linux	Notes: - nmap: https://www.upguard.com/blog/how-to-use-nmap#:~:text=If%20you're%20looking%20for,and%20carry%20out%20port%20scanning.
10	Group Formation and Discussion	Notes:

	-Group works in targeted area -library umpsa pekan -Individual task -Do a host discovering using nmap -Use nikto command to check the vulnerabilities in library website	-The network discovering is successful -There a few vulnerabilities found in library website
12	Group Formation and Discussion -Finalized the report before submitting Individual task: -Make sure my parts is already fixed according to the project rubric before submitting	Notes: -The project has been finalized before submitting

Student ID and Name: CA22025, Nur A'in Najwa Binti Nasra Project title: Vulnerabilities of library website in UMPSA Pekan		
Week	My weekly log	Reference used / notes
2	-Group Formation and Discussion - Discuss about group contract and title. Individual task; - Research for suitable area	Notes: -To understand project Requirement. -Refer to project guidelines.
3	Individual task; - Conduct research on common web vulnerabilities.	Notes: - OWASP Top 10 Web Vulnerabilities [https://owasp.org/www-project-top-ten/]
6	-Assigned roles to each group members. Individual task; - Documented initial findings. - Compare the most suitable and easiest tools to be use.	Notes: -Tools reviews from security blogs, lab manual.
8	Individual task;	Notes:

	- Download assigned tools and discover the fing. - Compare with other groups to make sure the steps lined out follow project requirements.	-Fing app user guide -Youtube tutorials (https://youtu.be/MdnTJeAuW0I?si=k6wED8Bo2ZuRyye0)
10	Individual task; - Conduct assets discovery using fing in target's network at library. - Find each devices' ip address and other information about the device. - Find vulnerabilities around the target's area like exposed wireless access point and open LAN ports. - Determine network topology based on assets discovery in the network.	Notes: - Walking around the library at each outlining zones and record the output. -Take pictures of vulnerabilities found. -Fing network scan report. -On-site visual inspection.
12	Individual task; - Explain to group members the result obtains. - Check reports format and align it with rubric given. - Make correction needed in before submit.	Notes: -Make sure all group members satisfied before submitting report.

Student ID and Name: CA22081, Auni Najihah Binti Jamarluddin
 Project title: Vulnerabilities of library website in UMPSA

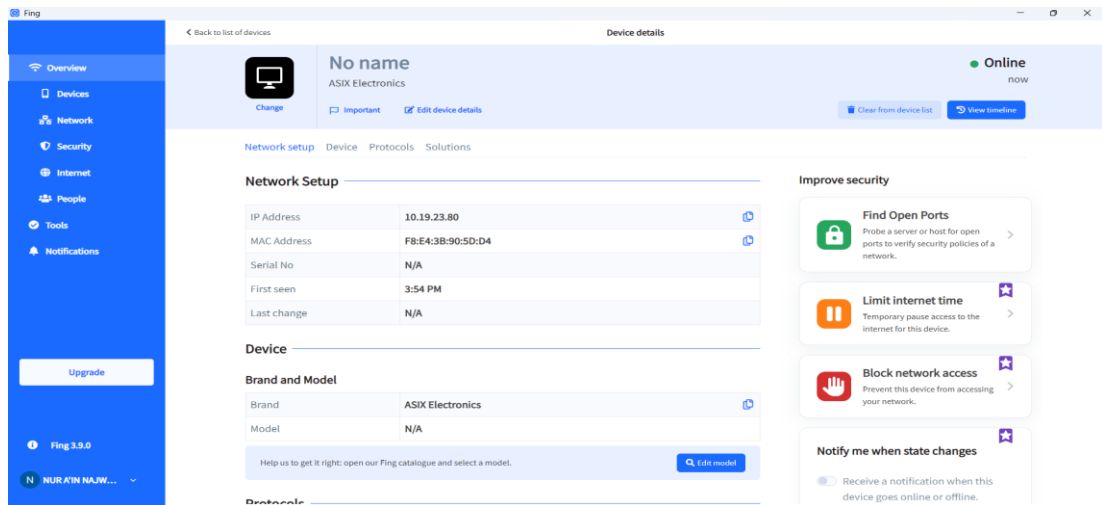
Week	My weekly log	Reference used / notes
------	---------------	------------------------

2	- Group Formation and Discussion - Discuss about group contract and title. Individual task: - Research for suitable	Notes: -To understand project requirement.
3	Individual task: - Conduct research on common web vulnerabilities.	Reference: MozDevNet. (n.d.). <i>Strict-transport-security header</i> - <i>http: MDN</i>. MDN Web Docs. https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security
6	Accept roles given by the leader. Individual task: - Identified tools and methodologies for developing remediation strategies	
8	Documented findings related to network vulnerabilities. Individual task: - Assisted in capturing photos of exposed access points and open ports in the library. - Collaborated with team members to align remediation strategies with identified vulnerabilities.	Notes: walking around the library to find any physical vulnerabilities at library.
9	Individual task: - Developed detailed remediation steps for each vulnerability. - Verified solutions	
10	Individual task: - Reviewed and refine the remediation steps. - Ensure consistency with ethical hacking principles and universities policy. - Determine the network topology.	
11	Individual task: - Collaborated on compiling final report. - Check reports format and align it with rubric given.	

	- Make correction needed in before submit.	
--	---	--

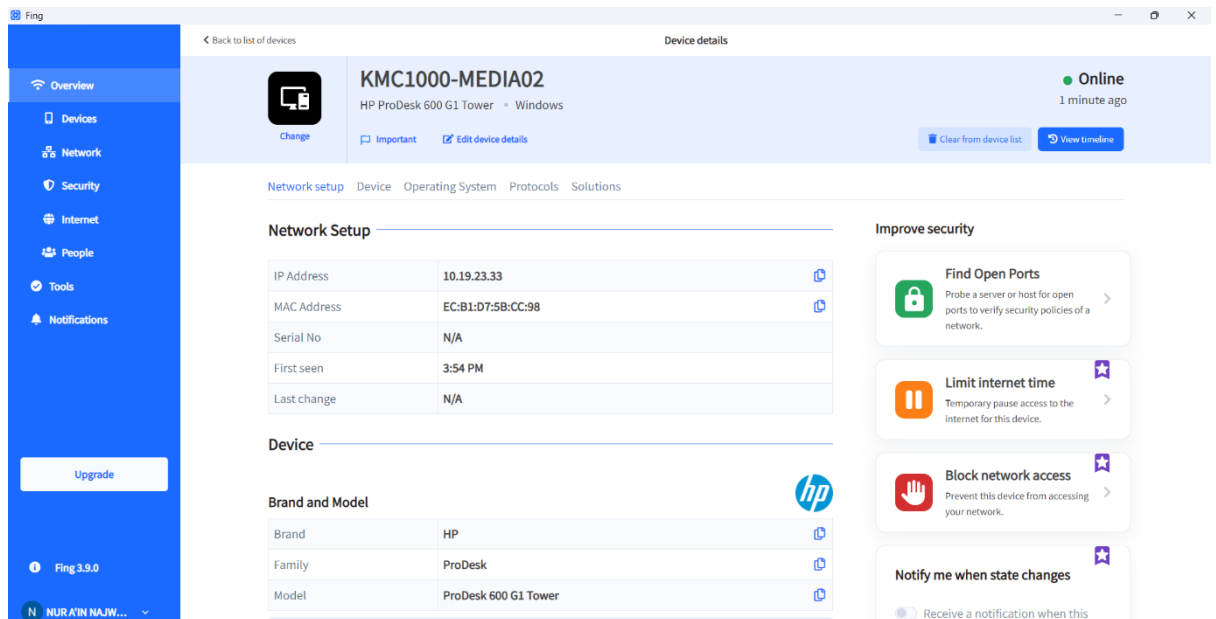
10. Appendix

A. Other devices' information found using fing.



The screenshot shows the Fing app interface for a device named "No name" (ASIX Electronics). The device is online. The interface includes a sidebar with navigation options: Overview, Devices, Network, Security, Internet, People, Tools, and Notifications. The main content area displays the following information:

- Network Setup:**
 - IP Address: 10.19.23.80
 - MAC Address: F8:E4:3B:90:5D:D4
 - Serial No: N/A
 - First seen: 3:54 PM
 - Last change: N/A
- Device:**
 - Brand and Model: ASIX Electronics
 - Model: N/A
- Improve security:**
 - Find Open Ports: Probe a server or host for open ports to verify security policies of a network.
 - Limit internet time: Temporary pause access to the Internet for this device.
 - Block network access: Prevent this device from accessing your network.
 - Notify me when state changes: Receive a notification when this device goes online or offline.



The screenshot shows the Fing app interface for a device named "KMC1000-MEDIA02" (HP ProDesk 600 G1 Tower). The device is online. The interface includes a sidebar with navigation options: Overview, Devices, Network, Security, Internet, People, Tools, and Notifications. The main content area displays the following information:

- Network Setup:**
 - IP Address: 10.19.23.33
 - MAC Address: EC:B1:D7:5B:CC:98
 - Serial No: N/A
 - First seen: 3:54 PM
 - Last change: N/A
- Device:**
 - Brand and Model: HP ProDesk 600 G1 Tower
 - Family: ProDesk
 - Model: ProDesk 600 G1 Tower
- Improve security:**
 - Find Open Ports: Probe a server or host for open ports to verify security policies of a network.
 - Limit internet time: Temporary pause access to the Internet for this device.
 - Block network access: Prevent this device from accessing your network.
 - Notify me when state changes: Receive a notification when this device goes online or offline.

Overview

Devices

Network

Security

Internet

People

Tools

Notifications

Upgrade

Fing 3.9.0

NUR A'IN NAJW...

Back to list of devices

Device details

Change

Important

Edit device details

Clear from device list

View timeline

DESKTOP-TV0E70L

Notebook NP5X_NP6X_NP7XPNK_PNH_PNJ • Windows 11 Home Version 24H2

Online

7 minutes ago

Network setup

Device

Display

Operating System

Protocols

Solutions

Network Setup

IP Address	10.19.23.83	
MAC Address	D4:93:90:0C:CD:4D	
Serial No	N/A	
First seen	3:54 PM	
Last change	N/A	
Hostname	DESKTOP-TV0E70L	

Device

Brand and Model

Brand	Notebook	
Model	NP5X_NP6X_NP7XPNK_PNH_PNJ	

Did Fing get it right?

Your feedback helps us improve device recognition results

Yes

No

Improve security

Find Open Ports

Probe a server or host for open ports to verify security policies of a network.

Limit internet time

Internet pause is disabled.

Block network access

Block is disabled.

Notify me when state changes

Receive a notification when this device goes online or offline.

Define how long a device must be absent to be

Overview

Devices

Network

Security

Internet

People

Tools

Notifications

Upgrade

Fing 3.9.0

NUR A'IN NAJW...

Back

Security • University Malaysia Pahang in Kuantan (10.19.23.0/24)

3 mins ago

Scan again

A context for University Malaysia Pahang in Kuantan (10.19.23.0/24) has not yet been assigned. Some features may be disabled. [Assign context](#)

Network security score

Unsecure

Secure

The network University Malaysia Pahang in Kuantan (10.19.23.0/24) returned a security score of 18 out of 100.

Score parameters are based on your network setup, reported vulnerabilities, active alerts and unconfirmed devices. [Learn more](#)

All

Passed

Attention needed

Insufficient protection

Inactive features

Performed security checks

7 Unconfirmed devices

Confirm your devices to easily spot who is using your network.

View timeline

Confirm devices

Access Point is secure

The access point is using a secure protocol to send data wirelessly.

View details

Inactive security checks

Notifications on new devices are disabled

Receive a notification when a new device joins your network.

Upgrade to unlock

Overview

Devices

Network

Security

Internet

People

Tools

Notifications

Upgrade

Fing 3.9.0

NUR A'IN NAJW...

Back

Network • University Malaysia Pahang in Kuantan (10.19.23.0/24)

4 mins ago

Scan again

Network Setup

Fing Network ID	eth-0A131700-18C47EE0744BC4	
Netmask	10.19.23.0/24	
Gateway IP Address	10.19.23.254	
Gateway MAC Address	C4:7E:E0:74:4B:C4	
Local Address	10.19.23.83	
DNS	172.16.100.30	
Interface Type	Ethernet	

Send export

Email a XLS export of your network details